

## **Case Study – Credit Unions**

Melvin Viado

Cybersecurity, Durham College

MGMT 1100: Business Process and Security Policy

Danny Aniag

October 4, 2025

## **Introduction**

Foundational planning, regulatory compliance, and organizational commitment is required for the task of developing, publishing, and adopting an information security policy as the Information Security Officer at Best Credit Union. The basis we are going to be guided by for our action plan to adopt an effective information security policy will be based on the rules and recommendations set out by the National Credit Union Administration among other federal regulations. Important questions throughout this actions plan including obstacles or challenges, personnel to include, methods on building support, and more will be addressed.

## **Foundation and Planning**

### **Regulation Requirements**

Credit unions are governed by a regulation environment where OK Credit Union will comply to several regulations. The National Credit Union Administration will regulate OK Credit Union and protects its members by ensuring that OK Credit Union develops and maintains an effective information security program specific to their operations. The NCUA will ensure that confidentiality, integrity, and availability of member information, protect against threats, and prevent unauthorized.

The Gramm-Leach-Bliley Act will apply to OK Credit Union as it is a financial institution. Lastly, the Federal Financial Institutions Examination Council and Financial Crimes Enforcement Network will apply cybersecurity and reporting regulations.

### **Initial Risk Assessment**

Best Credit Union will perform an assessment for what their risks are to clearly identify threats to their valuable assets. The assessment will involve the identification and listing of all sensitive information assets including employee data and financial information. Existing systems, devices, and technology used in daily operations will also be documented. Listing and taking into consideration of these asset points gives a clear point to what the potential vulnerabilities and threat vectors may be.

Assessing the current security controls and the degree of their effectiveness will be preceded by determining the acceptable risk levels OK Credit Union can tolerate. The information risk assessment will provide a solid foundation for the development of the information security policy and important assets must be documented.

## **Policy Development**

### **Leadership Support and Governance**

*Securing leadership support will be the method used to create support for the development process and the policy.* NCUA shall require the board of directors or the relevant committee to approve the information security program. They will establish clear lines of accountability throughout the organization and create methods for compliance monitoring.

### **Policy Design**

## **Safeguards**

Among key components of the action plan, the information security policy must address all areas identified and determined in the risk assessment while complying to the NCUA requirements. These areas will include safeguards for administration, technology, and physical spaces. OK Credit Union will address access control policies, background checks for employees, and training and training and awareness programs. Following that, encryption for data in transit and rest, authorization controls, monitoring detection, and vulnerability management will be addressed for the technology safeguards. Lastly, physical safeguards will be in place for facilities holding sensitive membership information, storage for paper and electronic media, and general equipment.

## **Documentation Requirements**

The written policy will include documentation for access and authentication controls, physical access restriction, and data encryption. Additionally, the policy will have documentation for testing schedules for security controls, division of duty requirements, media sanitation methods, and responsibility assignments for implementation of the security program.

## **Stakeholder Review and Approval**

### **Leveled Review Process**

The information security policy development process will require stakeholder review to ensure that the policy is comprehensive and practical. *The following will state the personnel at Best Credit Union that will be involved and who at OK Credit Union will be invited to participate in the development process of the information security policy.*

### **Personnel Involved**

Information security personnel, IT operation teams, compliance officers, legal team, and HR representatives from Best Credit Union will be involved in the policy development process to review the quality of the policy. Stakeholders of OK Credit Union such as department managers, operational staff, risk managers, and auditing representatives will also review the policy to ensure it aligns with business processes

### **Board Approval Process**

The approve process formally approved by the board of directors under NCUA regulations will include complete policy representation, review of risk assessment findings, and resources required for implementation and its timelines.

## **Implementation and Communication**

Dedicated personnel for the implementation will be assigned for its management, and budget will be allocated for the required technology and infrastructure. Timelines will be set for the implementation phases and completion will be accounted for. Existing procedures of the policy will be continually updated, technical controls will be made, methods of reporting and record-keeping systems will be available along with consistent documentation of system and process changes. Communication and training programs will allow this policy to be effectively adopted.

Announcement of the new policies, training for security responsible employees, and general awareness training will take place. Completing security training and understanding will also be updated, and methods for refreshing knowledge of security practices must be done regularly.

## **Testing and Validation**

### **Small Credit Union Examination Program (SCUEP)**

Assessment of OK Credit Union for the value of their total assets will depend on it SCUEP will apply such that the Union is under \$50 million USD in assets. They will be responsible for testing the critical controls, report the tests to the board, and any relevant testing documentation of OK Credit Union.

### **CORE Program**

OK Credit Union will be tested on technology controls, vulnerabilities, social engineering, and user access by the CORE program if the union has \$50 million USB or more in assets.

## **Ongoing Monitoring and Maintenance**

### **Annual Board Reporting**

Annual reports to the board of directors will describe the status of the information secure under the NCUA regulations which include results from risk assessments, testing important controls, security incidents, management responses, and other matters relevant to program effectiveness.

### **Continuous Improvement Process**

The information security program will change depending on the circumstances of OK Credit Unit affected by new technology and threats, new services or acquisitions, lessons learned by incidents or testing, and any regulatory changes made.

## **Challenges**

### **Resource Constraints**

*The biggest obstacle or challenge with creating an effective information security policy is the resource constraints.* Limited budgeting, insufficient staff, and outdated technology will create a challenge, especially if OK Credit Union is a smaller credit union with lower budgets and staff. This will not allow the union to create a comprehensive information security policy and will not address certain vulnerabilities properly of the organization.

## **Employee Concerns**

### **Change**

*Transparent communication will help employees that grumble about change.*

Communicating the benefits to the organization from the information security policy will help employees understand, where gathering their feedback and addressing their concerns with transparency will help empower them to ensure the success of policy changes.

### **Non-Compliance**

*Non-compliance with security policies will result in disciplinary actions including warning, retraining and supervision, suspension, or demotion or termination depending on the severity and risk to the credit union in alignment to protecting the organization.*

## References

- Hyder, F. (n.d.). *Steps to Information Security Program Development*. Ferro Technics.  
<https://www.ferrotechnics.com/resource/9-Steps-to-Information-Security-Program-Development>
- Khachatryan, A. (2025, August 20). *information security policies (+ features & benefits)*. Syteca.  
<https://www.syteca.com/en/blog/information-security-policies>
- Letter to Credit Unions. (n.d.). <https://ncua.gov/files/letters-credit-unions/LCU2006-07ENC.pdf>
- PowerDMS. (2025, August 11). *How to develop an effective information security policy*.  
<https://www.powerdms.com/policy-learning-center/how-to-develop-an-effective-information-security-policy>
- Tangney, D. (2025, February 21). *Credit Union Cybersecurity Compliance: A guide*. Compyl.  
<https://compyl.com/blog/guide-to-credit-union-cybersecurity-compliance/>